

사내 준법 서약 시스템 구축 제품 요구사항 정의서 (PRD)

Enterprise Compliance Agreement System

문서번호 KB-PRD-2026-001

작성일자 2026년 5월 7일

버전 v1.0

작성자 프로젝트 담당자

1. 프로젝트 개요

본 프로젝트는 사내 임직원의 보안 의식을 고취하고 준법 경영을 실현하기 위한 '사내 준법 서약 시스템' 구축을 목표로 합니다. 사용자가 PC를 이용해 업무를 시작하기 전 또는 주기적인 시점에 필수 보안 지침을 확인하고 서약할 수 있도록 제어하는 가두리(Lockdown) 방식의 윈도우 스크립트 기반 클라이언트와 이를 중앙 제어하는 백엔드 시스템으로 구성됩니다.

1.1 추진 배경 및 목적

- **보안 컴플라이언스 준수 강화:** 사내 정보 유출 방지 및 미승인 소프트웨어 사용 금지에 대한 정기적인 확약 필요.
- **서약 프로세스 자동화:** 수동 서약 프로세스를 전산화하여 임직원의 참여율을 100%로 보장하고, 감사 증적 자료를 실시간 자산화.
- **중앙 집중식 서약 관리:** 컴플라이언스 기준 변경에 따라 유연하게 서약 문구를 편집하고 대상자에게 신속하게 전파할 수 있는 환경 마련.

2. 시스템 아키텍처 개요

전체 시스템은 임직원 PC에 상주하는 **데몬 및 클라이언트(Python기반)**, 중앙에서 서약 데이터를 수집하고 문구를 관리하는 **API 및 임시 DB**, 그리고 관리자가 조작하는 **웹 관리자 페이지**의 3-Tier 레이어로 구성됩니다.

구성 요소	주요 역할	사용 기술 스택 (예시)
PC 클라이언트	주기적 API 조회, 전체화면 팝업 차단, SSO 및 단말 정보 연동, 서약 전송	Python 3.x, Tkinter, PyInstaller, Windows Registry
중앙 DB / API	서약 데이터 적재(로그), 서약 문구 제공 API, SSO 연동 검증	Relational DB (테스트용 SQLite/MySQL), RESTful API
웹 관리자 페이지	실시간 동의 현황 모니터링, 서약서 문구 편집 및 스케줄 관리	Web Framework (Flask / Django / React 등)

3. 상세 요구사항 정의 (Functional Requirements)

3.1 연동 및 데이터 수집 요구사항 (SSO & Client Info)

사용자 편의성을 극대화하고 동의 주체를 명확히 하기 위해 별도 로그인 없이 인프라 정보를 자동 수집합니다.

- **필수** **사내 SSO 연동**: 단말에 로그인된 사용자의 사번, 이름 정보를 내부 SSO 인프라 토큰 또는 환경 변수를 통해 안전하게 획득합니다.
- **필수** **PC 단말 정보 추출**: 서약이 이루어진 컴퓨터의 고유 식별을 위해 PC 호스트명(Host Name), IP 주소 및 MAC 주소를 자동으로 추출합니다.
- **필수** **데이터 무결성**: 수집된 정보(사번, 이름, PC정보, 동의 시간)를 하나의 트랜잭션으로 묶어 전송 데이터셋을 생성합니다.

3.2 데이터 전송 및 임시 DB 검증 요구사항

- **필수** **동의 로그 전송**: 사용자가 '확인 및 업무 시작' 버튼을 누르면 REST API를 통해 백엔드로 데이터가 즉시 전송되어야 합니다.
- **권장** **임시 DB 환경 구축**: 본 개발 및 인프라 이관 전, 연동 신뢰성 테스트를 수행할 수 있도록 간이 데이터베이스(SQLite 혹은 로컬 개발용 DB)를 구축하여 스키마를 검증합니다.

💡 데이터베이스 테이블 설계 구조 (안)

Table: COMPLIANCE_AGREEMENT_LOG

- LOG_ID (PK, Auto Increment)
- EMP_NO (사번, VARCHAR)
- EMP_NAME (이름, VARCHAR)
- PC_NAME (PC명, VARCHAR)
- IP_ADDRESS (IP주소, VARCHAR)
- AGREE_VERSION (서약 버전, VARCHAR)
- AGREED_AT (동의일시, TIMESTAMP)

4. 관리자 기능 및 동적 콘텐츠 제어

4.1 웹 관리자 페이지 (Back-office) 생성

- **서약 문구 관리 UI:** 준법지원부서 등 관리자가 코드를 수정하지 않고 웹 화면에서 서약서 제목과 본문(1개 또는 다수 조항)을 편집하고 [저장/배포]할 수 있는 기능 제공.
- **버전 관리 시스템:** 약관 변경 시 새로운 버전 번호(예: v1.0, v1.1)를 부여하여, 구 버전 동의자와 신 버전 동의자를 구분하여 통계 추출 가능.
- **현황 모니터링:** 사내 임직원 중 미동의자와 동의자의 실시간 현황 리스트 및 엑셀 다운로드 기능 제공.

4.2 동적 약관 파싱 및 클라이언트 렌더링

- 클라이언트 프로그램이 구동될 때 백엔드 API(예: /api/current-agreement)를 호출합니다.
- API 응답으로 전달된 최신 약관 내용(JSON 포맷)을 클라이언트가 해석하여 Tkinter 화면의 title_label과 content_label에 실시간 동적 매핑합니다.

5. 배포 및 실행 스케줄 제어 (Deployment & Scheduling)

5.1 자동 레지스트리 등록 및 인스톨러 파일 생성

- **필수 단일 실행파일화(EXE):** PyInstaller 등을 활용하여 Python 런타임이 없는 환경에서도 단독 실행되도록 가벼운 컴파일 진행.
- **필수 윈도우 시작프로그램 자동 등록:** 프로그램 최초 설치 또는 실행 시, 윈도우 레지스트리의 Run Key 영역에 실행 경로가 자동으로 주입되도록 로직 내포.

※ 레지스트리 경로: HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run

5.2 하이브리드 트리거 스케줄링 (주기적 / 특정 시간 조회)

사용자가 최초 1회 동의를 완료했다라도, 관리자가 지정한 정책에 따라 다음과 같은 스케줄링 방식으로 백엔드 API를 상시 조회하여 새로운 배포 건이나 정기 서약 건이 있을 시 화면에 팝업을 강제 표출합니다.

방법 A: 인터벌 기반 스케줄링 (1시간 주기)

프로그램이 백그라운드 데몬 형태로 상주하며 매 1시간(60분) 마다 중앙 서버의 /api/check-trigger를 호출합니다. 현재 로그인한 사번 기준 '새로 동의해야 할 서약서' 플래그가 반환되면 즉시 가두리 화면을 활성화합니다.

방법 B: 타겟 타임 기반 스케줄링 (지정 시간 특정 실행)

사내 업무 집중도 및 피크 타임을 고려하여 지정된 타겟 시점(예: 오전 09시 10분, 오후 13시 10분 등 하루 2~3회)에 정밀 동기화 타이머가 동작합니다. 해당 시각 정각에 서버 상태를 파악하여 서약이 누락되었거나 당일 재인증이 필요한 경우 팝업을 발생시킵니다.

6. 예외 처리 및 보안 요구사항

- **오프라인 예외 처리:** 네트워크 장애 등으로 API 서버와 통신이 불가능할 경우, 사용자 업무 마비를 방지하기 위한 예외 모드(로컬에 마지막 서약 캐싱 및 사후 전송 큐) 프로세스를 정립해야 합니다.
- **우회 차단 강화:** 기본 UI에서 구현된 Alt+F4 차단 외에, 작업 표시줄 강제 종료나 윈도우 단축키 우회를 방지하기 위해 상시 최상단(Topmost) 속성을 주기적으로 리프레시해야 합니다.